

MobileSec-MS — Analyse de sécurité des applications mobiles

Contexte

Les applications mobiles sont souvent publiées avec des vulnérabilités graves : clés API exposées, mauvaise gestion du stockage local, absence de chiffrement, ou encore manque de validation côté client. Les tests manuels de sécurité sont longs et coûteux, et les outils existants ne sont pas toujours adaptés à des pipelines DevSecOps continus. Une plateforme modulaire permettrait de détecter automatiquement ces failles lors de l'analyse statique ou dynamique.

Objectif

Développer une plateforme modulaire composée de microservices spécialisés permettant :

- l'analyse automatisée de fichiers APK/iOS (APK/IPA),
- la détection de vulnérabilités OWASP MAS (Mobile Application Security),
- l'extraction de bonnes pratiques manquantes (sécurité SSL, permissions, export, stockage),
- la suggestion de correctifs,
- l'intégration continue dans les workflows DevSecOps.

Architecture détaillée des microservices

1. APKScanner

- Rôle : Désassemble et analyse les APK pour extraire le manifest, les permissions et les endpoints.
- Technologies : Python (Androguard, Apktool), base SQLite pour métadonnées.
- Fonction : Identifie composants exportés, permissions dangereuses, debuggable, allowBackup, cleartextTrafficPermitted, etc.

2. SecretHunter

- Rôle : Recherche les secrets exposés dans le code ou les ressources.
- Technologies : GitLeaks, Regex personnalisées, YARA Rules.
- Fonction : Détecte clés API, tokens OAuth, mots de passe codés en dur, etc.

3. CryptoCheck

- Rôle : Vérifie l'utilisation correcte des API cryptographiques.
- Technologies : SAST Java/Kotlin, règles codifiées (CWE).

- Fonction : Détecte mauvais usages de AES/ECB, absence de padding, faiblesse dans le random, MD5/SHA1.

4. NetworkInspector

- Rôle : Intercepte les communications réseau via un proxy mitm.
- Technologies : mitmproxy, Docker sandbox Android (AVD).
- Fonction : Analyse HTTPS/TLS, en-têtes HTTP, gestion de certificats, fuites de données.

5. ReportGen

- Rôle : Agrège les résultats et génère des rapports PDF, JSON et SARIF.
- Technologies : Node.js, Puppeteer.
- Fonction : Génère une fiche détaillée des failles détectées et des recommandations correctives.

6. FixSuggest

- Rôle : Fournit des suggestions de correctifs ou configurations à appliquer.
- Technologies : Modèle de règles MASVS → YAML → patches.
- Fonction : Propose des actions concrètes : android:exported="false", activer Proguard, isoler signingConfig.

7. CIConnector

- Rôle : Intégration avec GitHub Actions / GitLab CI.
- Technologies : Docker CLI, plugins YAML.
- Fonction : Permet d'activer les scans automatiquement à chaque build.

Résultats attendus

- Détection rapide et automatisée des failles de sécurité mobiles.
- Aide à la conformité avec les normes OWASP MASVS, CWE, et CIS Mobile.
- Intégration fluide dans le cycle DevSecOps des applications Android/iOS.
- Plateforme extensible en open source, avec jeux d'exemples et rapports reproductibles pour publication dans SoftwareX.

Encadrants :

Pr. Oumayma OUEDRHIRI (O.ouedrhiri@emsi.ma)

Pr. Hiba TABBAA (H.Tabbaa@emsi.ma)

Pr. Mohamed LACHGAR (lachgar.m@gmail.com)